AI Identity Security Policy

Table of Contents

1 Identity Lifecycle Management

1.1 Provisioning

1.2 Review and Attestation

1.3 Rotation

1.4 Decommissioning

2 Credential Governance

2.1 API Key Rotation Schedule

2.2 Prohibition on Long-Lived Agent Credentials

2.3 Secrets Management Standards

3 Incident Response Playbook

3.1 Scenario A — Leaked LLM API Key

3.2 Scenario B — Compromised Agent Identity

3.3 Scenario C — Prompt Injection Leading to Data Exfiltration

4 Policy Enforcement and Exceptions

1. Identity Lifecycle Management

Every AI agent, orchestrator and machine-to-machine (M2M) service in SecureNova must have its own identity in Auth0. These identities must not be shared between agents or used interchangeably with human user accounts.

This section explains how agent identities are created, reviewed, maintained, and eventually decommissioned, along with the timelines that must be followed.

1.1 Provisioning

- Each agent is assigned a separate Auth0 application. M2M applications are used for autonomous agents, while Regular Web Applications are used for user-facing agents. Sharing or reusing client IDs is not permitted.
- Agents are given only the permissions needed to perform their assigned tasks. For example, the standard AI agent starts with `read:ai-data` access. Administrative permissions such as `write:admin` are not granted by default.
- Every issued token includes a unique `agent_id` claim. This is configured through an Auth0 Action so that activities can be traced back to the agent that performed them.
- A provisioning request must be submitted through the service catalogue. It requires approval from both the agent owner and the security team and should be completed within two business days.
- Before an agent is moved into production, its threat model (Project 1) and IAM design (Project 2) must be completed and documented.

1.2 Review and Attestation

Agent access must be checked regularly to make sure that permissions remain appropriate and that unused identities do not retain access.

- The agent owner reviews each agent's permissions every 90 days, including its assigned scopes, token lifetime and continued business requirement.
- A complete access certification covering all agent identities takes place every 180 days. The CISO office is responsible for reviewing and signing off on the results.
- Agents that have been inactive for more than 30 days are flagged for review. Their access is suspended until the owner confirms that they are still needed.
- Records of each review, including the reviewer, date and outcome, must be kept for 12 months.

1.3 Rotation

Credentials and signing keys must be changed regularly to reduce the risk of unauthorised access if they are exposed.

- Agent client secrets and API keys must be rotated at least once every 90 days, or immediately if there is any suspicion that they have been compromised. Further details are covered in Section 2.1.
- Access tokens used by agent APIs have a maximum lifetime of 300 seconds (5 minutes). For user-facing agents, refresh-token rotation and reuse detection must also be enabled.
- Ed25519 signing keys used to authenticate messages between agents are rotated every 180 days. A period of overlapping validity is maintained during rotation to prevent service interruptions.
- Rotation should be automated wherever possible. If it has to be carried out manually, it must be completed within 24 hours of the scheduled rotation or emergency request.

1.4 Decommissioning

When an agent is no longer required, its access must be removed promptly so that its credentials cannot be used again.

- Within 24 hours of a decommissioning request, the agent's Auth0 application, client secret, API grants and signing keys must be revoked.
- All refresh tokens and active sessions associated with the agent must be revoked immediately, and its token family must be invalidated.
- The retired `agent_id` must not be assigned to another agent in the future.
- The decommissioning activity must be recorded, and the supporting evidence retained for 12 months for audit and investigation purposes.

2. Credential Governance

Credentials used by AI agents need to be protected carefully because a single exposed key could allow someone to access customer data or privileged APIs. SecureNova therefore follows clear rules for issuing, storing and rotating credentials. These rules apply to all agent and machine-to-machine (M2M) identities.

2.1 API Key Rotation Schedule

All agent and M2M credentials follow a maximum 90-day rotation schedule. The table below is binding:

Credential type	Maximum lifetime	Rotation trigger	Owner
M2M client secret	90 days	Scheduled + on exposure	Agent owner
Third-party LLM / API key	90 days	Scheduled + on exposure	Platform team
Access token (agent API)	300 seconds	Automatic (expiry)	Auth0
Refresh token	Rotating, single-use	Every use (rotation + reuse detection)	Auth0
Ed25519 agent signing key	180 days	Scheduled + on compromise	Security team

Rotation is tracked in the secrets register; an overdue credential is a policy violation and is escalated to the CISO office.

2.2 Prohibition on Long-Lived Agent Credentials

AI agents must not rely on credentials that remain valid indefinitely or are left unchanged for long periods. Static API keys without a rotation process, access tokens lasting more than five minutes and secrets configured with no expiry are not permitted.

The following rules must also be followed:

- Credentials must never be placed directly in source code, system prompts, container images or other locations where an LLM could access or expose them.
- If a third-party service only supports long-lived API keys, requests must go through a short-lived-token broker. The original key must remain securely stored in the secrets manager and must not be accessible directly to the agent.
- Any human-interactive login used for agent operations must be protected with MFA.
- Agents must authenticate using the OAuth client-credentials flow. Storing or using a human user's password for agent operations is not allowed.

2.3 Secrets Management Standards

All credentials and sensitive keys must be stored using an approved secrets manager, such as a cloud vault or an environment-injected secrets service. They must never be kept in plaintext files that are committed to source control.

The following practices are mandatory:

- Every repository must have a `.gitignore` file, or an equivalent configuration, that excludes `.env` files and other credential material. Repositories must also be scanned for exposed secrets before they are published.
- Credentials must not appear in application logs, screenshots or error messages. Whenever output needs to be shared, sensitive values must be replaced with `[REDACTED]`.
- Access to stored secrets must follow the principle of least privilege, and all access must be logged. Any retrieval of a production secret must generate an audit event.
- If a credential is suspected of being exposed, for example through a screenshot or a source-code commit, it must be treated as compromised and rotated immediately, following the schedule in Section 2.1.

3. Incident Response Playbook

This playbook explains how the SecureNova team should respond to three common AI identity security incidents. Each scenario follows the same five steps: **Detection, Containment, Evidence Preservation, Notification, and Recovery.**

The severity of an incident must be assessed as soon as it is reported. If there is confirmed exposure to customer data, the incident must be classified as High or Critical and immediately escalated to the CISO on call.

3.1 Scenario A — Leaked LLM API Key

This scenario covers situations where a credential used to access the LLM provider or SecureNova backend API is exposed. This could happen through a source code commit, a support ticket, a screenshot or an application log.

Detection Signals

The team may identify a leaked credential through any of the following signs:

- A secret-scanning tool raises an alert after detecting a key in a source-code commit, ticket or log. A notification from the third-party provider about an exposed key is also treated as a warning.
- An unusual increase in LLM API requests is detected. For example, an agent making more than 20 requests within 60 seconds should trigger an alert, as covered in Project 4's anomaly detection.
- API requests start coming from unfamiliar IP addresses, locations or user agents, such as `curl`, `python requests` or headless clients.
- Unexpected changes appear in the LLM provider's billing activity or rate-limit usage.

Containment

Once the exposure is confirmed, the team must act quickly to prevent further misuse.

- Revoke the exposed key and issue a replacement immediately. The old key must no longer be usable.
- If the exposed credential is a SecureNova M2M client secret, rotate it through Auth0 and invalidate any tokens that depend on it.

- Apply IP-based throttling and brute-force protection. If the affected agent continues to pose a risk, temporarily disable it until the issue is resolved.

Evidence Preservation

Before making changes, the team should preserve as much information about the exposure as possible.

- Record where the key was exposed, including the relevant commit hash, ticket ID or screenshot. Provider access logs should also be collected before rotation wherever possible.
- Save anomaly-detection alerts, Auth0 logs and API gateway logs with their timestamps. All evidence must be stored in the incident evidence store using write-once protection.

Notification

- Once the leak is confirmed, notify the CISO on-call and the responsible agent owner within one hour.
- If there is a possibility that customer data was accessed, involve the legal and privacy teams to assess whether breach notification is required under applicable regulations.

Recovery

- Test the replacement key to make sure it works and confirm that the exposed key has been completely revoked.
- Check for any unauthorised changes made during the incident, including newly created API grants, Auth0 Actions or user accounts.
- Complete a post-incident review within five business days. Update the detection rules and secrets register based on the findings.

3.2 Scenario B — Compromised Agent Identity

This scenario occurs when an attacker manages to operate using the identity of a legitimate AI agent. This could happen by forging an inter-agent message or using a stolen token to perform actions that the attacker should not be allowed to access.

Detection Signals

The following signs may indicate that an agent identity has been compromised:

- Ed25519 signature verification failures appear in the logs for messages exchanged between agents.
- The permissions associated with an agent change unexpectedly between consecutive requests. For example, an agent that previously had only `read:ai-data` suddenly makes a request with `write:admin` access. This is also monitored through Project 4's anomaly detection.
- An expired token is used again, or refresh-token reuse causes the associated token family to be revoked.
- Privileged operations, such as `grant_admin_scope` or `reset_mfa`, are performed in ways that do not match the agent's normal activity.

Containment

The priority is to stop the compromised identity from performing any further actions.

- Suspend the affected agent identity and immediately revoke its active sessions, access tokens and token family.
- Rotate the agent's signing key and client secret. The agent must then be enrolled again using a new key pair.
- Block the suspicious source IP addresses and enable additional verification for related identities where necessary.

Evidence Preservation

The team must retain the information needed to understand how the identity was compromised and what actions were performed.

- Preserve any forged or replayed messages, signature verification failures, token audit records and the agent's recent activity history.
- Take timestamped copies of the relevant Auth0 and agent runtime logs and store them in the write-once incident evidence store.

Notification

- Notify the CISO on-call and the owners of any downstream systems that the compromised agent could access within one hour.
- If the agent has performed actions involving privileged or sensitive data, initiate the data-exposure assessment and follow the privacy notification process.

Recovery

- Provision the agent again with new credentials and a verified signing key. Confirm that signature verification is enforced before any inter-agent message is processed.
- Review the authorization controls and make sure the system does not trust an agent's identity based only on a plain-text header. Also verify that the agent has only the scopes required for its assigned tasks.
- Complete a post-incident review within five business days and improve the relevant detection rules based on the findings.

3.3 Scenario C — Prompt Injection Leading to Data Exfiltration

This scenario covers attacks where untrusted content, such as an uploaded document, a RAG knowledge-base entry or a tool response, contains hidden instructions. These instructions may manipulate the AI agent into exposing sensitive information or sending data to an unauthorised destination through a tool.

Detection Signals

The team should look for the following warning signs:

- Input guardrails detect or block suspicious instructions. Examples include phrases such as `ignore previous instructions`, fake system notes, hidden HTML comments, spoofed agent headers and requests for secrets.
- Output guardrails detect credential-like values in model responses, such as JWTs, and trigger the configured redaction mechanism.
- The agent attempts to call tools to send information to unapproved destinations. Examples include sending emails to unfamiliar external addresses or using Markdown image links as tracking beacons.
- The RAG pipeline retrieves documents from unexpected repositories or entries that have been modified recently without an approved reason.

Containment

Once a possible prompt-injection attack is identified, the team must prevent the affected content or tool from causing further damage.

- Block the suspicious input source and quarantine the affected document or RAG knowledge-base entry until it has been reviewed.
- Temporarily disable the agent's access to the tool involved in the incident. Tool calls based on untrusted content should remain restricted until the issue is investigated.
- If any credential has been exposed in the process, treat it as compromised and follow the containment steps described in Scenario A.

Evidence Preservation

The original attack details should be retained so the team can reproduce and investigate the incident.

- Preserve the exact malicious input, the context retrieved by the RAG pipeline, the model's response and any attempted tool calls. All records must include timestamps.
- Record which protection layer detected the attack, whether it was the input rules, Prompt Guard model or output redaction mechanism. This information will help improve the guardrails later.

Notification

- Notify the CISO on-call and the relevant data owner within one hour.
- If customer personally identifiable information (PII) has left the SecureNova security boundary, involve the legal and privacy teams to assess breach-notification requirements.

Recovery

- Remove the affected content from the knowledge base and re-index it after the content has been reviewed and cleaned.
- Update the guardrail detection rules to recognise similar attack patterns in the future.
- Test the same attack against the updated pipeline to confirm that the guardrails now detect and block it. Record the results as before-and-after validation evidence.

4. Policy Enforcement and Exceptions

All employees and teams working with the SecureNova platform are expected to follow this policy. Any violation, such as an overdue credential, an agent using a long-lived API key or a secret being committed to source code, must be recorded as a security finding. The issue should then be addressed based on its level of risk and potential impact.

If a team needs an exception to any of these requirements, it must obtain written approval from the CISO office. The request must clearly explain why the exception is needed, identify the additional security measures (compensating controls) that will be used, and include an expiry date. No exception can remain valid for more than 90 days.

This policy is reviewed once every six months to make sure it remains relevant to the SecureNova environment. However, if a High or Critical AI identity security incident occurs, the policy must be reviewed sooner rather than waiting for the next scheduled review.

The following project documents and supporting records are maintained as related security artefacts:

- Project 1 – Threat Model
- Project 2 – IAM Design
- Project 3 – Red-Team Findings
- Project 4 – Blue-Team Controls
- Compliance Mapping – NIST AI RMF and OWASP LLM Top 10